Máster Universitario en Ciberseguridad

VNiVERSiDAD D SALAMANCA



CIBERINTELIGENCIA

Tema 4: Inteligencia de amenazas cibernéticas

Pablo Chamoso (chamoso@usal.es)
Sergio Alonso (sergio.alro@usal.es)



Máster Universitario en Ciberseguridad

Tabla de contenidos

1. Introducción
2. Inteligencia de amenazas
3. Indicadores de ciberinteligencia
4. Plan de ciberinteligencia
5. Casos de uso
6. Conclusiones y recursos adicionales

Objetivos del tema

- Comprender qué es la **inteligencia de amenazas** y por qué es clave en ciberdefensa.
- Definir el **rol del analista** y su interfaz con SOC, IR y gestión de riesgos.
- Diferenciar **niveles de inteligencia**: estratégica, táctica y operativa (público, valor y ejemplos).
- Identificar y aplicar **IoC** e **IoA** con contexto, calidad y caducidad adecuados.
- Diseñar un **plan de CTI** completo: planificación/dirección → recogida (fuentes) → procesamiento → análisis → informes/difusión → retroalimentación.
- Trasladar la inteligencia a **casos de uso**: detección, *threat hunting*, priorización de vulnerabilidades y respuesta.

1. Introducción

Datos e información

- **Dato:** valor individual y discreto; sin contexto. Se organiza en estructuras (logs, tablas, eventos).
- **Información:** datos procesados + contexto que **responden preguntas** (p. ej., “¿cuántos dispositivos consultan el mismo servicio web en un intervalo?”).
- **De dato a información:** estructurar → relacionar → agregar → interpretar.
- **Finalidad:** la información genera **conocimiento accionable**, base de la inteligencia de amenazas.

1. Introducción

Inteligencia

- **Definición general:** capacidad de resolver problemas y tomar decisiones beneficiosas.
- **En informática:** proceso que usa información disponible para responder **requisitos de conocimiento**.
- **Transformación clave:** del **qué/cómo** (datos e información) al **por qué/cuándo** (intención y oportunidad).
- **Flujo: Datos → Información → Hipótesis/Análisis → Producto de inteligencia → Decisión/Acción**.
- **Resultado: conocimiento interpretado y accionable** que sustenta decisiones y respuestas de la organización.

1. Introducción

Relación entre inteligencia y datos

- **Dato/Info en crudo ≠ inteligencia.**
- Solo es **inteligencia** si el resultado es **aplicable a los objetivos de negocio**.
- Debe **apoyar decisiones** o **habilitar acciones** específicas.
- Requiere **juicio**: contexto, relevancia, oportunidad y fiabilidad.

"Saber mucho no es lo mismo que ser inteligente. La inteligencia no es solo información, sino también juicio, la manera en que se recoge y maneja la información". - Carl Sagan

2. Inteligencia de amenazas

¿Qué es la inteligencia de amenazas?

- **Definición:** conocimiento **accionable** sobre ciberamenazas (actores, motivaciones, capacidades, TTPs, **IoC/IoA**).
- **Objetivo:** pasar de **reactivo** a **proactivo**; **anticipar y mitigar** ataques que afectan **C-I-D**.
- **Preguntas clave: quién** ataca, **por qué**, **cómo/cuándo/dónde** y **con qué indicios** detectarlo.
- **Fuentes típicas: OSINT/SOCMINT**, HUMINT, TECHINT, **logs**, tráfico de red y **dark web**.
- **Proceso: recopilar → procesar → analizar → difundir** productos útiles para detección y respuesta.
- **Valor:** decisiones **más rápidas e informadas**, priorización y respuesta coordinada.

2. Inteligencia de amenazas

¿Por qué es importante?

- Amenazas más persistentes y **volumen masivo de datos** → análisis manual inviable; *feeds* sin contexto = más carga.
- La **CTI** convierte datos en **inteligencia con contexto** (actores, motivación, **TTPs**, **IoC/IoA**) e integra con **SOC/SIEM/SOAR**.
- **Automatiza** recolección/procesamiento (estructurado y no estructurado) y **prioriza por riesgo**; puede apoyarse en **IA**.
- Habilita **postura proactiva/predictiva**: anticipar campañas, guiar parches y controles.
- Impacto: menos **ruido/FP**, mejor **MTTD/MTTR**, ahorro de costes y seguridad reforzada (red y nube).
- **Red Team:** emulación de **TTPs** probables para validar defensas con escenarios realistas.

2. Inteligencia de amenazas

El papel del analista de ciberinteligencia

- Vigila y analiza datos de amenazas para producir **inteligencia accionable**.
- Clasifica incidentes desde **múltiples fuentes CTI** (feeds, logs, OSINT/dark web).
- Estudia **patrones/TTPs**, motivaciones, severidad y **panorama** de la amenaza.
- **Filtra y enriquece**: contexto, IoC/IoA y relaciones actor–campaña.
- Elabora **informes y recomendaciones** para dirección/CISO, SOC e IR.
- **Prioriza riesgos** y apoya decisiones de detección, contención y mejora continua.

2. Inteligencia de amenazas

Tipos de inteligencia de amenazas

- **Estratégica:** dirección/CISO → tendencias, riesgos y prioridades a **largo plazo**.
- **Táctica:** SOC/IR → **TTPs** y vectores (p. ej., MITRE ATT&CK) para **defensas concretas**.
- **Técnica:** automatización/SIEM → **IoC** (IPs, dominios, hashes, URLs, muestras); **alta caducidad** (días).
- **Operacional:** campañas/actores → **quién-cómo-cuándo-por qué** de ataques en curso; **accionable** a **corto plazo**.

2. Inteligencia de amenazas

Inteligencia estratégica

- **Propósito:** visión del panorama y riesgos para la **decisión de alto nivel**.
- **Audiencia/producto:** ejecutivos/CISO; **informes** claros y poco técnicos.
- **Contenido clave:** riesgos por líneas de acción, patrones de actores/TTP y **tendencias geopolíticas**.
- **Fuentes:** documentos estatales/ONG, **prensa** general/sectorial, **libros e informes** de seguridad y expertos.
- **Proceso:** partir de **RI/preguntas concretas**; requiere enfoque **sociopolítico y de negocio**.
- **Escala/soporte:** volúmenes masivos y multilingües → **automatizar** recolección/procesamiento; el analista **interpreta y sintetiza**.

2. Inteligencia de amenazas

Inteligencia táctica

- **Propósito:** describir **TTPs** del adversario y guiar **defensas concretas**.
- **Audiencia/producto:** SOC/IR y arquitectura; **detecciones**, *playbooks*, reglas (Sigma/YARA/Snort) mapeadas a **MITRE ATT&CK**.
- **Fuentes:** informes de *vendors*/ISACs, *advisories* (CVE/CVSS, CISA KEV), telemetría propia (**SIEM/EDR/NDR**).
- **Contenido clave:** vectores, herramientas/infra C2, **vulns explotadas**, **técnicas de evasión**.
- **Uso práctico:** priorizar **parches/hardening**, crear/ajustar reglas y **threat hunting** dirigido.
- **Caducidad:** corta (días–semanas) → **actualización continua** y TTL para IoCs.
- **Integración:** contexto sectorial y **risk scoring**; orquestación con **SOAR** para respuesta.
- **Pregunta guía:** "¿Nos afecta, dónde, cómo lo detectamos y **qué cambiamos hoy**?"

2. Inteligencia de amenazas

Inteligencia operativa

- **Propósito:** contexto **accionable y a corto plazo** para SOC/IR.
- **Contenido:** vector, **vulns explotadas**, infra/C2, dominios, artefactos, **ventana temporal** e intención.
- **Fuentes:** *feeds* técnicos (IoC), OSINT/dark web, foros/canales cerrados, **telemetría propia**; gran solapamiento con la **inteligencia técnica**.
- **Barreras: acceso** (privado/cifrado/idiomas), **ruido** (alto volumen) y **ofuscación** (nombres en clave).
- **Mitigación: ML/NLP** para ingesta multilingüe y correlación; automatización + **revisión humana**; mapeo a **MITRE ATT&CK**.
- **Operativa: alertas** y *playbooks*; **TTL/priorización** de IoC; guiar contención, *hunting* y respuesta.

3. Indicadores de ciberinteligencia

Concepto

- Distinguir **IoC** vs **IoA** es clave al implantar un programa de CTI.
- **IoC (Indicadores de Compromiso)** → **¿QUÉ?** Artefactos observables: IPs, dominios, URLs, hashes, firmas.
- Uso: detección/contención **reactiva**; alta caducidad.
- **IoA (Indicadores de Ataque)** → **¿POR QUÉ/CÓMO?** Intención y comportamiento (TTPs, objetivos, patrones).
- Uso: **prevención** y detecciones basadas en comportamiento; más **duraderos**.
- **En conjunto:** IoC para filtros automatizados + IoA para contexto y *playbooks* → decisiones más rápidas y precisas.

3. Indicadores de ciberinteligencia

Indicadores de compromiso

- **Qué son:** evidencias técnicas de intrusión, normalmente **reactivas** y basadas en historial.
- **Ejemplos:** IP/dominio/URL maliciosos, **hashes** de malware, **firmas/reglas** (AV/IDS), artefactos de explotación.
- **Ámbito: host-based** (sistema) y **network-based** (red).
- **Categorías: atómicos**, **computados** (p. ej., regex, hashes) y de **comportamiento** (combinaciones lógicas).
- **Usos:** detección/bloqueo en SOC y **confirmación forense**; apoyo a **threat hunting** con patrones conocidos.
- **Limitaciones: alta caducidad** y **fácil evasión** (Pirámide del Dolor); rara vez cubren fases tempranas.
- **Buenas prácticas:** añadir **contexto** (actor/TTP/campaña), definir **TTL** y **confianza**, enriquecer y **desduplicar**; mapear a **ATT&CK**.

3. Indicadores de ciberinteligencia

Indicadores de ataque

- **Enfoque:** intención y **comportamiento** (POR QUÉ/CÓMO), independiente de malware/exploit → clave para intrusiones **sin malware** y **0-day**.
- **Señales típicas: EBA**/telemetría en tiempo real, secuencias de eventos y llamadas a DLL, acciones del usuario/endpoint, **persistencia** y **TTPs**.
- **Ventaja:** detección **temprana** y más **duradera** (centrada en TTPs) → postura **proactiva**.
- **Vs IoC:** IoC = **QUÉ/artefacto** (caducidad corta); IoA = **intención/proceso** (madura en el tiempo).
- **Requisitos: EDR/XDR + logs**, analítica/big data y **contextualización**; mapear a **MITRE ATT&CK**, *playbooks* y **revisión humana**.
- **Riesgos/retos:** integración y **gobernanza** complejas; necesidad de **priorización** para reducir falsos positivos.

4. Plan de ciberinteligencia

Planificación y dirección

- **Enfocar la pregunta:** un solo hecho/evento/actividad; evitar preguntas amplias.
- **Decisión que habilita:** ¿qué decisión concreta permitirá la respuesta y **para cuándo**?
- **Quién consume:** perfil y **formato** (SOC/IR técnico y rápido vs. ejecutivo estratégico).
- **Priorizar RI:** alineación con valores/estrategia, **impacto**, **urgencia** y coste de oportunidad.
- **Criterios de éxito:** nivel de confianza, alcance temporal/geo, fuentes permitidas y limitaciones.
- **Ciclo de feedback:** puntos de control, ajustes y cierre con lecciones aprendidas.

4. Plan de ciberinteligencia

Recogida

- **Objetivo:** reunir datos **relevantes** para los RI (qué, para quién, ventana temporal, formato).
- **Fuentes internas:** logs de red/endpoint, EDR/XDR, SIEM, incidentes previos, inventario de vulnerabilidades.
- **Fuentes externas: OSINT/SOCMINT** (buscadores, WHOIS/DNS, *paste sites*, noticias/redes), **dark web**, *threat feeds* y *advisories*.
- **CCI:** *honeypots*, **Passive DNS**, *sinkholes*, pivoteo de infraestructura del adversario, **reglas YARA**.
- **HUMINT** (acceso legítimo): entrevistas, foros/canales cerrados; respetar marco legal/ToS.
- **Análisis de malware:** estático/dinámico/sandbox → IoC personalizados, TTPs, infra/C2.
- **A escala:** integrar/ETL, **normalizar y deduplicar**, etiquetar **fuente–confianza–TTL**, preservar trazabilidad.
- **Salida:** conjunto **curado y priorizado** listo para procesamiento y análisis.

4. Plan de ciberinteligencia

Fuentes de CyberThreat Intelligence: Tipologías

- **Técnicas (OSINT):** *feeds* de IoC, listas de IPs/dominos, hashes, repos de *threat intel*. → **Riesgo:** muchos falsos positivos; validar y poner **TTL**.
- **Foros de cibercriminales:** anuncios de MaaS, leaks, *how-tos* y ofertas de acceso. → **Riesgo:** acceso complejo/engaños; cruzar con otras fuentes.
- **Dark web:** marketplaces, dumps, canales cerrados. → **Riesgo:** barreras de acceso y ruido; OPSEC estricto.
- **Medios de comunicación:** noticias, *advisories* y reportes sectoriales. → **Riesgo:** difícil mapear a **riesgo propio**; enriquecer con contexto.
- **Redes sociales (SOCMINT):** investigadores comparten IoCs y TTPs. → **Riesgo:** veracidad variable; exigir **corroboración**.

4. Plan de ciberinteligencia

Fuentes de CyberThreat Intelligence: Destacadas

- **AlienVault OTX:** intercambio abierto de inteligencia (IoC, pulsos, contexto).
- **Cisco Talos Intelligence:** informes y *feeds*; ecosistema **Snort/ClamAV**.
- **Spamhaus Project:** *realtime intel* sobre spam/botnets/dominios/IPs maliciosos.
- **CISA (AIS): Automated Indicator Sharing** para intercambio estandarizado de IoCs.
- **FBI InfraGard:** información para sectores críticos y colaboración público-privada.
- **SANS Institute:** formación, *whitepapers* y *handlers diaries* para *situational awareness*.
- **VirusTotal:** análisis colaborativo de archivos/URLs/IPs y relaciones entre artefactos.

4. Plan de ciberinteligencia

Procesamiento

- **ETL automatizado:** ingesta → **normalización** → **validación** → **deduplicación** → agregación.
- **Estructura común:** almacenar en SIEM/data lake/BD de grafos; esquemas y campos consistentes.
- **Etiquetado de metadatos: fuente**, **timestamp/UTC**, **confianza**, **TTL**, tipo (IoC/IoA).
- **Correlación y filtrado:** reglas (casos de uso) y controles de calidad para reducir **FP/FN**.
- **Presentación útil: tablas y gráficos con contexto** operativo para acelerar la acción.
- **Trazabilidad:** conservar originales y **logs** del pipeline para auditoría y reproducción.

4. Plan de ciberinteligencia

Análisis

- **Objetivo:** detectar problemas y **notificar** según los RI definidos.
- **Proceso: buscar → interpretar → ilustrar** patrones en datos internos/externos ya procesados.
- **Métodos:** correlación, timelines, mapeo a **MITRE ATT&CK**, **risk scoring** y priorización.
- **Calidad:** precisión, **nivel de confianza**, trazabilidad y supuestos explícitos.
- **Productos por audiencia:** listas curadas/IoC accionables, **sitrep** técnico, **informe ejecutivo**.
- **Salida accionable:** hipótesis y **recomendaciones** (detecciones, mitigaciones, respuesta) con criterios de éxito.

4. Plan de ciberinteligencia

Informes de inteligencia y difusión

- **Entregar a la persona adecuada, en el momento adecuado** (SLA y canal: SIEM/SOAR, ticketing, *briefings*, email seguro).
- **Formato por audiencia:**
- **Estratégico:** tendencias, impacto y riesgo → decisiones y presupuesto.
- **Operacional:** medidas y recomendaciones claras → *playbooks*, priorización.
- **Táctico:** TTPs, IoC/IoA, reglas (Sigma/YARA/Snort) y mapeo ATT&CK (con **TTL**).
- **Calidad y cumplimiento:** nivel de **confianza**, fuentes y trazabilidad; clasificación y **need-to-know**.
- **Cierre del ciclo:** *feedback* y lecciones aprendidas; actualizar detecciones/controles.
- **Métricas de valor:** adopción de controles, bloqueos efectivos, **MTTD/MTTR**, ↓ falsos positivos.

4. Plan de ciberinteligencia

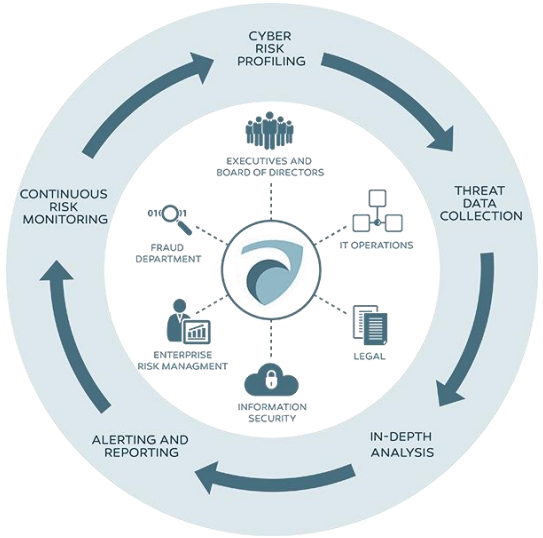
Retroalimentación

Inteligencia sobre contenido y metadatos **públicos** de redes sociales, foros, blogs para apoyar decisiones operativas/tácticas/estratégicas.

- **Límites:** sin acceso a información privada ni elusión de controles; **acceso legítimo** únicamente.
- **Principios:** legalidad, proporcionalidad y respeto a la privacidad.
- **Relación con OSINT:** misma familia, **foco específico** en el ecosistema social digital.
- **Hacia dónde va (2025+):** IA autónoma, análisis **multimodal** en tiempo real, detección avanzada de inautenticidad, **predictivo** mejorado, personalización (con salvaguardas) y **cumplimiento/ética** automatizados.

5. Casos de uso

- **Cyber Risk Profiling:** inventario y criticidad de activos, amenazas probables y **RI**.
- **Threat Data Collection:** ingesta desde **fuentes internas** (logs, EDR/SIEM) y **externas** (OSINT, dark web, feeds CTI).
- **In-Depth Analysis:** correlación, **ATT&CK**, **IoA/IoC**, *risk scoring* y priorización.
- **Alerting & Reporting:** difusión al **SOC/IR** y a ejecutivos con **medidas concretas** y *playbooks*.
- **Continuous Risk Monitoring:** métricas (MTTD/MTTR, FP/TP), efectividad de controles y **retroalimentación** al perfilado.



5. Casos de uso

Respuesta a incidentes

- **Problema:** alto volumen de alertas, muchos **falsos positivos** y presión de tiempo.
- **Aporta la CTI:**
  - **Triage automático:** descartar FPs con reputación, *whitelists* y **IoC/IoA validados**.
  - **Enriquecimiento en tiempo real:** actor/TTP/campaña, **risk scoring** personalizado y prevalencia (global vs. interna).
  - **Correlación interno–externo:** pivotar de artefactos a infra/C2; mapear a **MITRE ATT&CK** para entender alcance y pasos siguientes.
  - **Acción inmediata:** guías de contención/erradicación y **hardening** priorizado.
- **Impacto medible:** ↓ **ruido (FP)**, ↓ **MTTD/MTTR**, mejores decisiones y trazabilidad del caso.
- **Ciclo IR + CTI: Antes** (playbooks basados en CTI) → **Durante** (enriquecer y decidir) → **Después** (lecciones aprendidas, actualizar detecciones y **TTL** de IoC).

5. Casos de uso

Operaciones de ciberseguridad

- **Problema:** volumen masivo de alertas → fatiga, triage lento y casos sin investigar.
- **Qué aporta la CTI:**
  - **Priorización por riesgo:** *risk scoring* según actor/TTP + criticidad del activo.
  - **Enriquecimiento automático:** contexto (campaña, prevalencia, geo, *kill chain*), **IoC/IoA validados** y TTL.
  - **Correlación y deduplicación:** unir eventos relacionados, suprimir ruido y *benign true*.
  - **Ingeniería de detecciones:** mapeo **MITRE ATT&CK**, *coverage map*, reglas Sigma/YARA/Snort ajustadas.
  - **Automatización SOAR:** *playbooks* para contención, ticketing y escalado.
  - **Listas de vigilancia:** actores/infra observados, *watchlists* por sector/tecnología.
- **Métricas de éxito:** ↓ falsos positivos, ↓ **MTTD/MTTR**, ↑ porcentaje de alertas investigadas, tiempo ahorrado por analista.

5. Casos de uso

Gestión de vulnerabilidades

- **Problema:** backlog enorme y **CVSS ≠ riesgo**; recursos de parcheo limitados.
- **Aporta la CTI:**
  - **Priorizar por riesgo real:** explotación activa (**CISA KEV**, **EPSS**), **PoC** disponible, actores/sector.
  - **Contexto de exposición:** ¿internet-facing?, criticidad del activo (“crown jewels”), rutas ATT&CK.
  - **Enriquecimiento de hallazgos:** correlación con telemetría interna y controles compensatorios.
  - **Watchlists/alertas:** nuevas vulns del *stack* y avisos cuando surge explotación “in the wild”.
  - **Decisión y timing:** parcheo vs **mitigación temporal** (hardening, WAF/EDR, segmentación).
- **Impacto medible:** ↓ backlog crítico, ↑ % vulns explotadas remediadas en plazo, ↓ ventana de exposición y eventos de alto impacto.

5. Casos de uso

Análisis de riesgos

- **Objetivo:** priorizar decisiones de seguridad por **probabilidad × impacto**.
- **Aporte CTI:**
  - actores/TTPs,
  - **explotación activa**
  - exposición real y tendencias.
- **Proceso:** activos & apetito → escenarios ATT&CK → **probabilidad (evidencia CTI)** → **impacto (negocio)** → tratamiento & KPIs.
- **Salidas:** ranking de riesgos, **heatmap**, *owners* y plazos; **gaps** de detecciones/controles.
- **Métricas:** ↓ riesgo residual, ↓ MTTD/MTTR, ↑ % técnicas ATT&CK cubiertas, **tiempo a parchear** vulns explotadas.

6. Conclusiones y recursos adicionales

Conclusiones

- La **CTI** convierte datos en **decisiones accionables**: de IoC/IoA + TTPs a medidas concretas.
- Equilibrar **estratégica–táctica–operativa** según audiencia (ejecutivo, SOC/IR).
- **IoC** (corta vida) sin **contexto** aportan poco; prioriza **IoA/TTPs** y mapeo **MITRE ATT&CK**.
- Integrar con **SIEM/EDR/SOAR**, definir **TTL** y **nivel de confianza**, y cerrar el **ciclo de feedback**.
- Métricas clave: ↓ ruido/FP, ↓ **MTTD/MTTR**, ↑ cobertura ATT&CK y ↓ **riesgo residual**.

6. Conclusiones y recursos adicionales

Recursos adicionales

- **Marcos/estándares:** MITRE **ATT&CK** / **D3FEND**, **STIX/TAXII**, **TLP**, NIST (CSF, 800-61), **VERIS**.
- **Prioridad de vulns: CISA KEV**, **EPSS**, **CVE/NVD**.
- **Plataformas CTI: MISP**, **OpenCTI**; reglas **Sigma**, **YARA**.
- **Fuentes/feeds útiles: OTX (AlienVault)**, **Cisco Talos**, **Spamhaus**, **VirusTotal**, ISAC/ISAO sectoriales.
- **Buenas prácticas:** *playbooks* SOAR, plantillas de informes por audiencia y **checklists** de calidad/ética.